

# AAA -- Authorization -- Guided Notes ANSWER KEY

Unit tp-6.6 | CompTIA Network+ N10-009 Obj. FC0-U71 6.1 | N10-008 FC0-U71 6.1

For instructor use / distribute after students complete the notes.

---

## Question 1

Authorization (the second A in AAA) determines what a verified user is \_\_\_\_\_ to do after they authenticate. Authentication proves \_\_\_\_\_ the user is; authorization defines \_\_\_\_\_ they can access and what \_\_\_\_\_ they can perform.

*Answer: Permitted (allowed); who; what; actions.*

## Question 2

Role-Based Access Control (RBAC) assigns permissions based on \_\_\_\_\_ rather than individual identity. A nurse role has different access than a \_\_\_\_\_ role. Permissions are granted to \_\_\_\_\_, and users inherit permissions by being assigned a role. This is easier to \_\_\_\_\_ at scale than per-user permissions.

*Answer: Job role (function); physician/admin (any role); roles; manage.*

## Question 3

The principle of \_\_\_\_\_ privilege states that each user or system component should have only the \_\_\_\_\_ permissions required to perform their job -- nothing extra. This limits \_\_\_\_\_ in the event of a compromised account. If an accountant is compromised, they should not be able to access \_\_\_\_\_ source code or patient records.

*Answer: Least; minimum; damage; production.*

## Question 4

Mandatory Access Control (MAC) uses \_\_\_\_\_ labels (e.g., Top Secret, Confidential) assigned by the system or administrator. Users can only access resources at or \_\_\_\_\_ their clearance level. MAC is common in \_\_\_\_\_ and government environments. Discretionary Access Control (DAC) lets the \_\_\_\_\_ owner set permissions.

*Answer: Sensitivity; below; military; resource.*

## Question 5

Privilege \_\_\_\_\_ is a common attack where an attacker exploits a vulnerability to gain \_\_\_\_\_ access than authorized. Horizontal escalation means gaining access to \_\_\_\_\_ user accounts at the same level. Vertical escalation means gaining \_\_\_\_\_ (admin or root) privileges from a standard user account.

*Answer: Escalation; more; other; elevated.*

## Question 6

An Access Control List (ACL) is a list attached to a resource (file, folder, network port) that specifies which \_\_\_\_\_ or \_\_\_\_\_ are allowed or denied access. On Linux file systems, each file has \_\_\_\_\_

(read/write/execute) permissions for owner, \_\_\_\_\_, and others. On Windows, NTFS uses ACLs to control file and folder access.

*Answer: Users; groups; rwx; group.*

#### Question 7

Separation of duties requires that critical tasks are \_\_\_\_\_ across multiple people so no single person can complete a sensitive action alone. For example, the person who \_\_\_\_\_ a payment should not be the same person who \_\_\_\_\_ it. This is a key internal control that reduces \_\_\_\_\_ and financial fraud.

*Answer: Split (divided); initiates (creates); approves; insider threats.*

#### Question 8 -- Real World Application

REAL WORLD: A software company gives all engineers admin rights to the production database because it is more convenient during development. One engineer's laptop is infected with malware. The malware uses the engineer's stored database credentials to export the entire customer database containing 2 million email addresses and passwords. Explain the authorization failure and describe two specific controls that would have limited the impact.

*Answer: Authorization failure: violation of least privilege. Engineers were granted admin rights -- the maximum permission level -- for convenience, not necessity. Most day-to-day engineering work requires read access to specific tables, not admin rights to the entire production database. When the credentials were stolen, the attacker inherited full admin access, allowing them to export all data.*

*Control 1 -- Least-privilege role assignment: engineers should have read-only access to specific tables needed for their work in production. Only DBAs with a demonstrated need should have admin rights, and those credentials should be stored in a secrets manager with time-limited access tokens, not saved in IDE configs or laptops. Control 2 -- Database activity monitoring (DAM) and anomaly detection: log all database queries and alert on bulk data exports. A single query selecting 2 million rows at 2am should trigger an immediate alert and optional automated block. Even if the attacker had the credentials, the bulk export would be flagged before completion.*